

Chapter 5

Anonymity, Security, Privacy, and Civil Liberties¹
Ethical and Legal Framework for Information¹

By Dr. Ali Algarni

Outlines

- Anonymity
- Security
- Privacy
- Surveillance
- Privacy Protection and Civil Liberties
- Ethical and Legal Framework for Information

Recap

- Ethical Theories
 - Govern and shape the ethics, law, and code of conduct, code of eth
- Code of Ethics vs Code of Conduct
 - govern decision making vs govern actions
- Decision Making Framework
 - Guidelines and code of conducts (or ethics)
- Society, Morality, Ethics and Law
 - Digital and cyber societies/communities vs traditional

Anonymity, Security, Privacy, and Civil Liberties

- Information has increased in value
- The demand for information is high due to:
 - High digitalization of information and increasing bandwidth.
 - Declining costs of digital communication
 - increased miniaturization/mobility of portable computers and other communications equipment.
 - Greater public awareness by the news media of the potential abuse of digital communication, especially the Internet.
- The danger for misuse is real

Anonymity

- What is “Anonymity” ?
 - Absence of identity
 - The state of being nameless, having no identity.
- It is extremely difficult for anybody to live a meaningful life while one is totally anonymous.
- There are two common types of anonymity:
 - Pseudo identity.
 - Untraceable identity.

Anonymity

- Pseudo Identity
 - An individual is identified by a certain pseudonym, code, or number (similar to a writer's pen name).
 - The most common variant of anonymity.
- Untraceable Identity
 - One is not known by any name including pseudo names.

Anonymity on the Internet

- The nature of the Internet, with its lack of political, cultural, religious, and judicial boundaries, has created opportunities for all faceless people to come out in the open.
- In particular, the Internet provides two channels through which anonymous acts can be carried out:
 - Anonymous servers : (by encryption)
Types of anonymous servers : Anonymous & pseudonymous.
 - Anonymous users:
- All anonymity types are not 100 % anonymous.
- Anybody with a basic knowledge of computing networking would know, there is always a possibility to find those who misuse the Internet.

Anonymity on the Internet

- Anonymity has its good and bad sides.
- Advantages:
 - Checking unhealthy activities within an organization.
 - National security.
 - Some relationships and security of some people.
- Disadvantages:
 - Criminals can use it to their advantage, especially in online social networks.

Anonymity Vs. Single Identity



Security

- **security** can be considered a means to prevent unauthorized access, use, alteration, and theft or physical damage to property
- It involves these three elements (CIA):
 1. **Confidentiality**: To prevent unauthorized disclosure of information to third parties.
 2. **Integrity**: To prevent unauthorized modification of files and maintain the status quo
 3. **Availability**: To prevent unauthorized withholding of information from those who need it when they need it.

Physical Security

- A facility is **physically secure** if it is surrounded by a barrier such as a fence, has secure areas both inside and outside the facility, and can resist penetration by intruders.
- Physical security can be guaranteed by using four mechanisms
 - **Deterrence** to try to defend systems against intruders who may try to gain access. It works by creating an atmosphere intended to scare intruders.
 - **Prevention** used in mechanisms that work by trying to stop intruders from gaining access.
 - **Detection** assumes the intruder has succeeded or is in the process of gaining access to the system. It tries to “see” that intruder who has gained or who is trying to gain access.
 - **Response** is an aftereffect mechanism that tries to respond to the failure of the first three mechanisms. It works by trying to stop and/or prevent damage or access to a facility.

Physical Security (NCA ECC)



Essential Cybersecurity Controls

(ECC – 2: 2024)

2-14	Physical Security
Objective	To ensure the protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage.
Controls	
2-14-1	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall be identified, documented, and approved.
2-14-2	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall be implemented.
2-14-3	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall include the following as a minimum: 2.14.3.1 Authorized access to critical areas within the entity (e.g. the entity's data center, disaster recovery center, critical information processing facilities, security surveillance center, network connection rooms, technical device and equipment supply areas, etc.). 2.14.3.2 Access and monitoring logs (CCTV). 2.14.3.3 Protection of access and monitoring log information. 2.14.3.4 Security of the destruction and re-use of physical assets that hold classified information (including paper documents and storage media). 2.14.3.5 Security of devices and equipment inside and outside the entity's facilities.
2-14-4	Cybersecurity requirements for protection of information and technology assets of the entity against unauthorized physical access, loss, theft, and damage shall be periodically reviewed.

Physical Access Controls

- **Physical access control** → physical barriers + electronic protocols
 - authenticate the user of the resource.
- **Physical Security Barriers:**
 - hinder access to a protected resource including fences, brick walls, mounted motion detection sensors, security lighting, closed-circuit television (CCTV),
 - The area surrounding the facility can be secured using locks and keys, window breakage detectors, infrared and ultrasonic detectors, interior microwave system or dogs.
- **Electronic Access Controls**
 - more invasive electronic controls that include card access control systems and firewalls and password to secure the inside.

Electronic Access Controls: Password

- **Password** is a string of usually six or more to verify a user to an information system facility, usually digital system.
- Password security greatly depends on the password owner observing all of **these four “never” cardinal rules**:
 - Never publicize a password.
 - Never write a password down anywhere.
 - Never choose a password that is easy to guess.
 - Never keep the same password for an extended period of time.

Electronic Access Controls: Password

external resource: Microsoft 365 Admin

- Password rules in organization policy ?
- Good password practices fall into a few broad categories
 - Resisting common attacks:
 - Containing successful attacks
 - Understanding human nature
- Password guidelines for administrators
 - Educate users to not reuse their organization passwords for nonwork purposes
 - Enforce registration for multifactor authentication
 - Enable identity protection risk policies
 - Configure password resets paired with an authentication app.

Electronic Access Controls: Password

external resource: Microsoft 365 Admin

- Password guidelines for users
 - Don't use a password that is the same or similar to one you use on any other websites
 - Set passwords that are hard to guess to avoid **brute-force password attacks** (next Slide)
 - Easy to guess passwords like
 - abcdefg
 - password
 - monkey
 - 123456
- **Example:** ISO/IEC 27001 international standard for managing information security
 - A.9.4 (2023)
 - A 5.17 (2022)

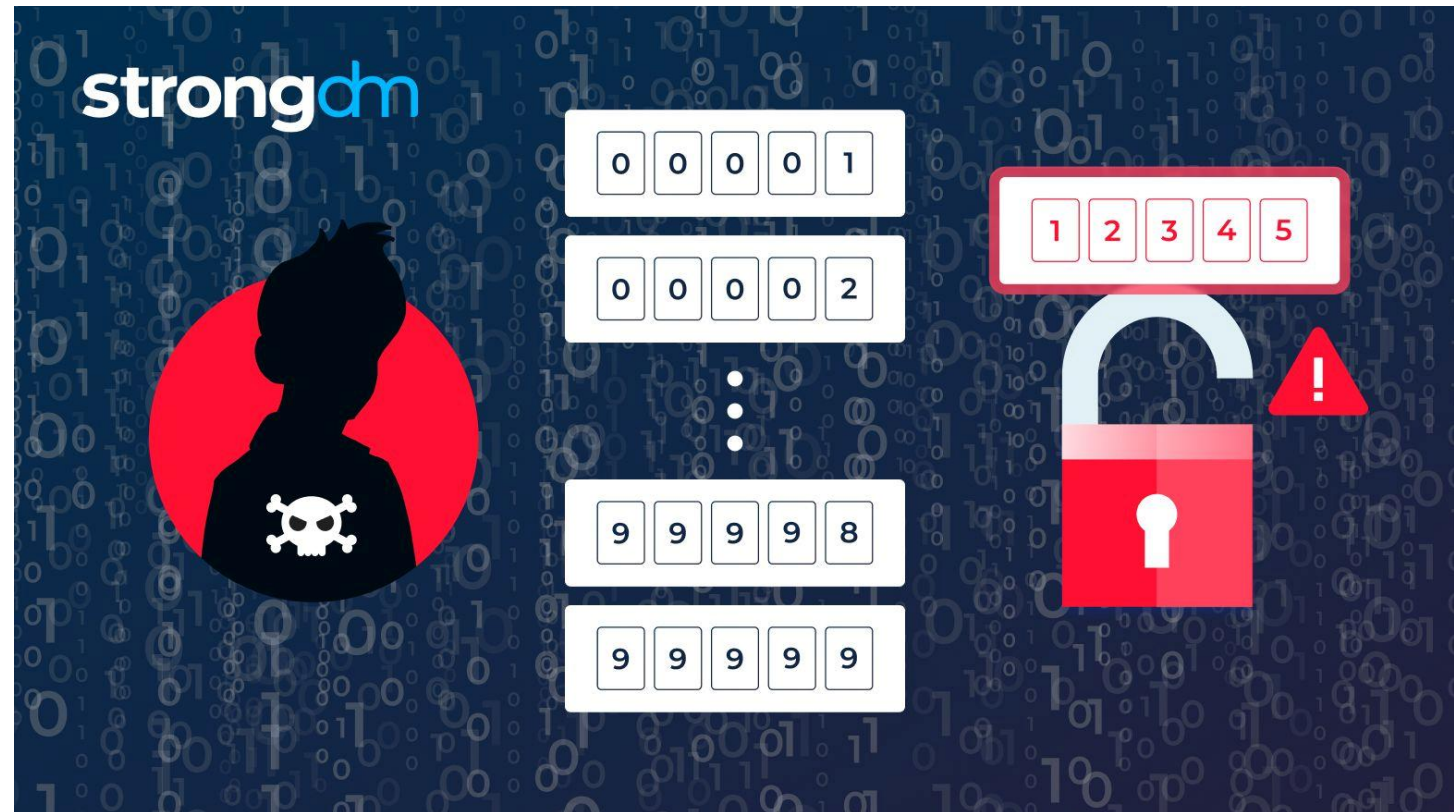
Electronic Access Controls: Password

external resource: Microsoft 365 Admin

Time it takes a hacker to brute force your password in 2025					
Hardware: 12 x RTX 5090 Password hash: bcrypt (10)					
Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	57 minutes	2 hours	4 hours
6	Instantly	46 minutes	2 days	6 days	2 weeks
7	Instantly	20 hours	4 months	1 year	2 years
8	Instantly	3 weeks	15 years	62 years	164 years
9	2 hours	2 years	791 years	3k years	11k years
10	1 day	40 years	41k years	238k years	803k years
11	1 weeks	1k years	2m years	14m years	56m years
12	3 months	27k years	111m years	917m years	3bn years
13	3 years	705k years	5bn years	56bn years	275bn years
14	28 years	18m years	300bn years	3tn years	19tn years
15	284 years	477m years	15tn years	218tn years	1qd years
16	2k years	12bn years	812tn years	13qd years	94qd years
17	28k years	322bn years	42qd years	840qd years	6qn years
18	284k years	8tn years	2qn years	52qn years	463qn years

 **Hive Systems**

Read more and download at hivesystems.com/password



Electronic Access Controls: Firewall

- A **firewall** is hardware or software used to isolate the sensitive portions of an information system facility from the outside
- Limit the potential damage that can be done by a malicious intruder.
- Most firewalls are variations of the following three models:
 - **Packet filters:** They contain gates that allow packets to pass through if they satisfy a minimum set of conditions and choke or prevent those packets that do not meet the entry conditions
 - **Proxy servers:** Work on the protected portions of the network that usually provide information to outside users requesting access to those portions.
 - **Stateful inspection:** These firewalls combine both the filter and proxy functions. Because of this, it is considered complex and more advanced

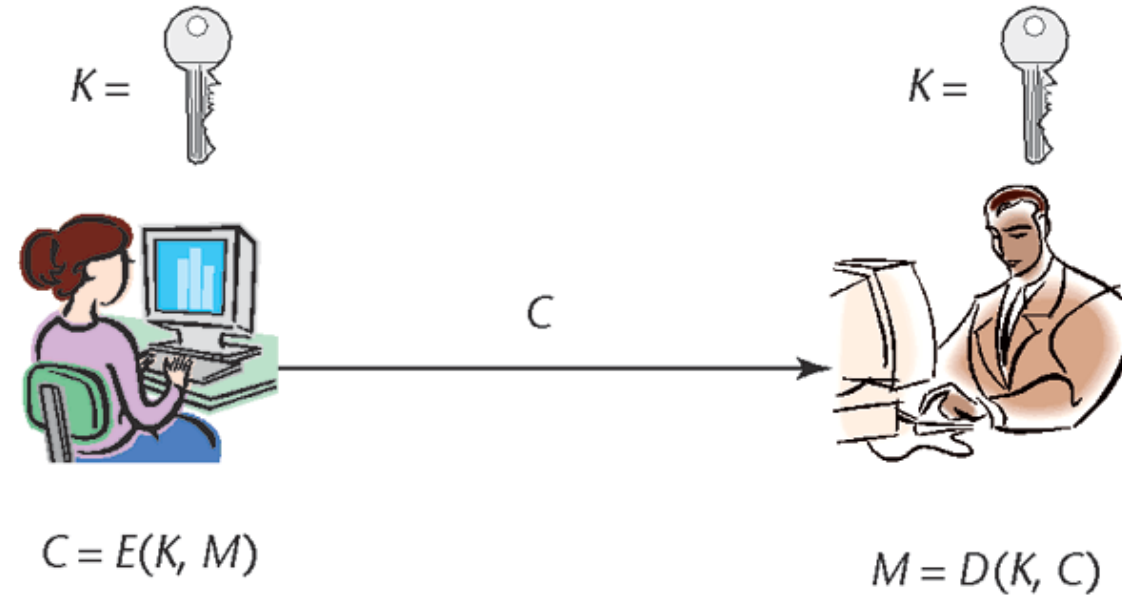
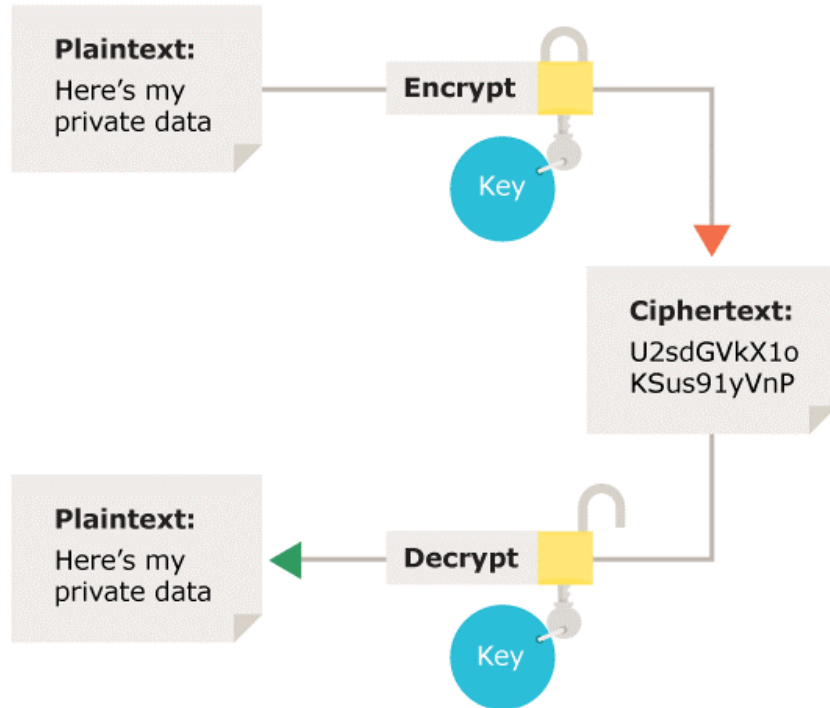
Information Security Controls

- The security of information can be ensured in a number of ways. The most common are **cryptography** for information *transmission, authentication and audit trail*.
- **Cryptography**, the science of writing and reading coded messages, forms the basis for all secure transmission. This is done through three functions: symmetric encryption, asymmetric encryption, and hash functions.
- It is a method that protects the communications channel from sniffers or unauthorized accesses.
 - sniffers are programs written for and installed on the communication channels to eavesdrop on network traffic, examining all traffic on selected network segments.
- Cryptography uses an encryption algorithm and key to transform data at the source, called **plaintext**; turn it into an encrypted form called **ciphertext**, usually an unintelligible form.

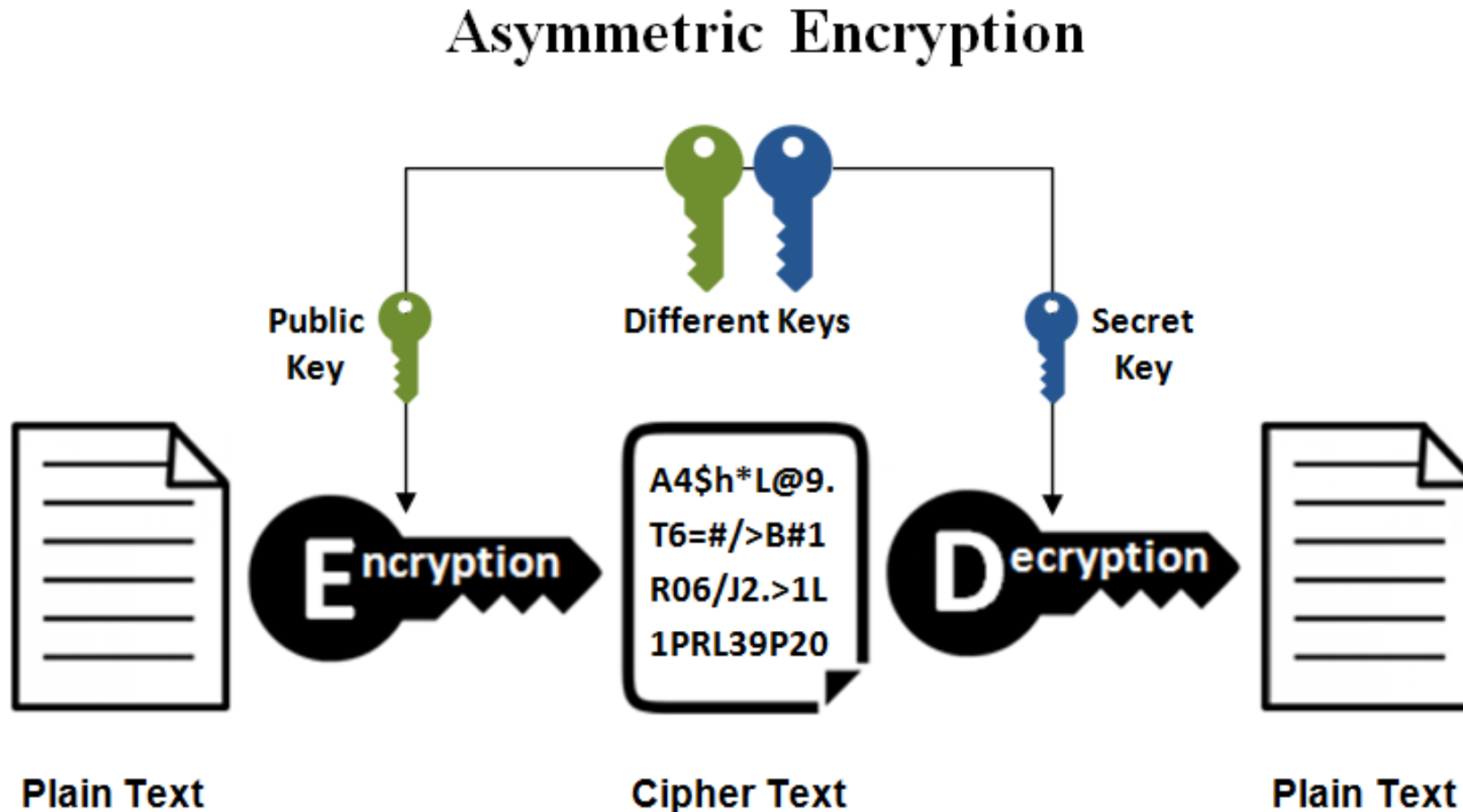
Encryption

- **Symmetric encryption**, or **secret-key encryption** uses a common key and the same cryptographic algorithm to scramble and unscramble the message
 - One problem with symmetric encryption is the security of the keys which must be passed from the sender to the receiver (key distribution)
- **Asymmetric encryption**, commonly known as public-key encryption, uses two different keys, a public key known by all and a private key known by only the sender and the receiver
- **Hash function** takes an input message M and creates a code from it. The code commonly referred to as a hash or a message digest. A one-way hash function is used to create a digital signature of the message—just like a human fingerprint. The hash function is therefore used to provide the message's integrity and authenticity.

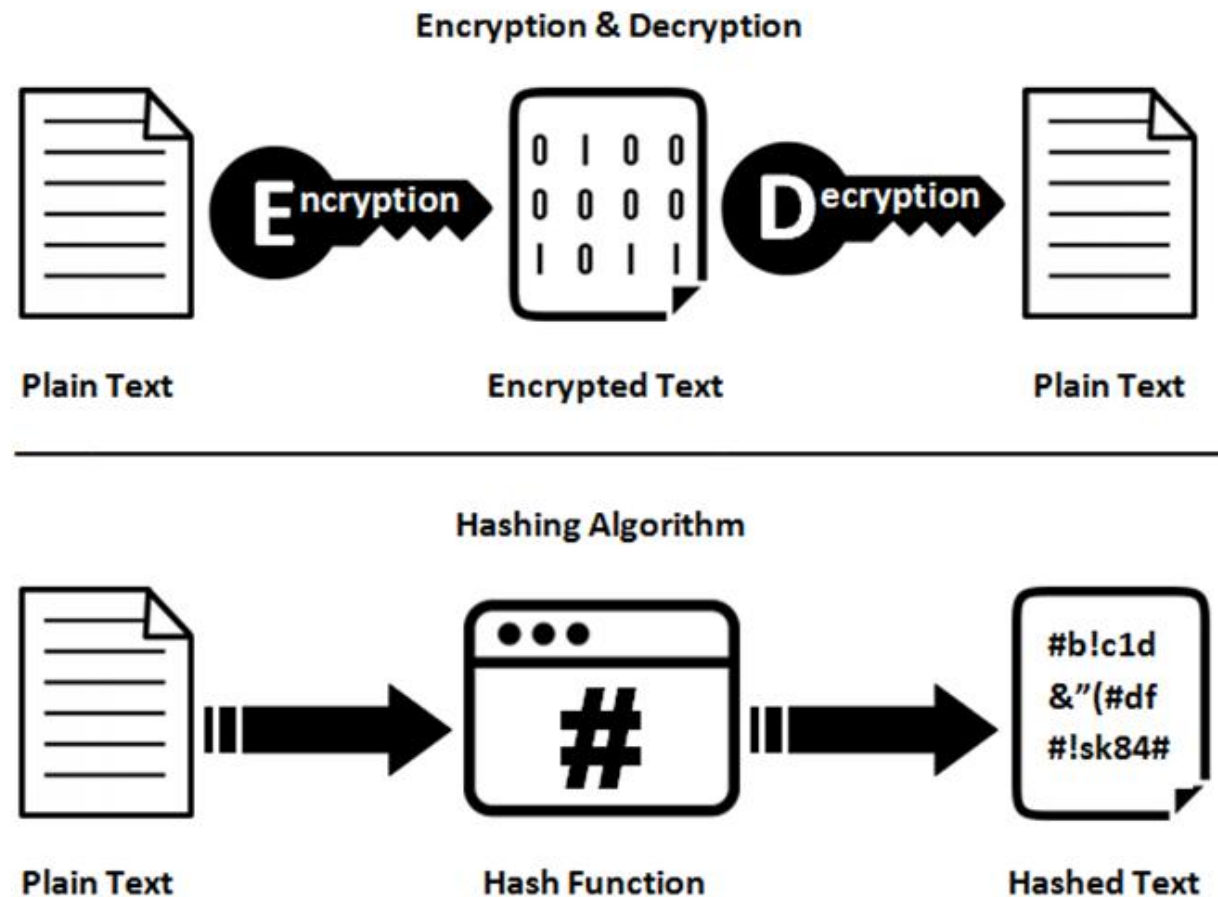
Symmetric Cryptography



Asymmetric Cryptography



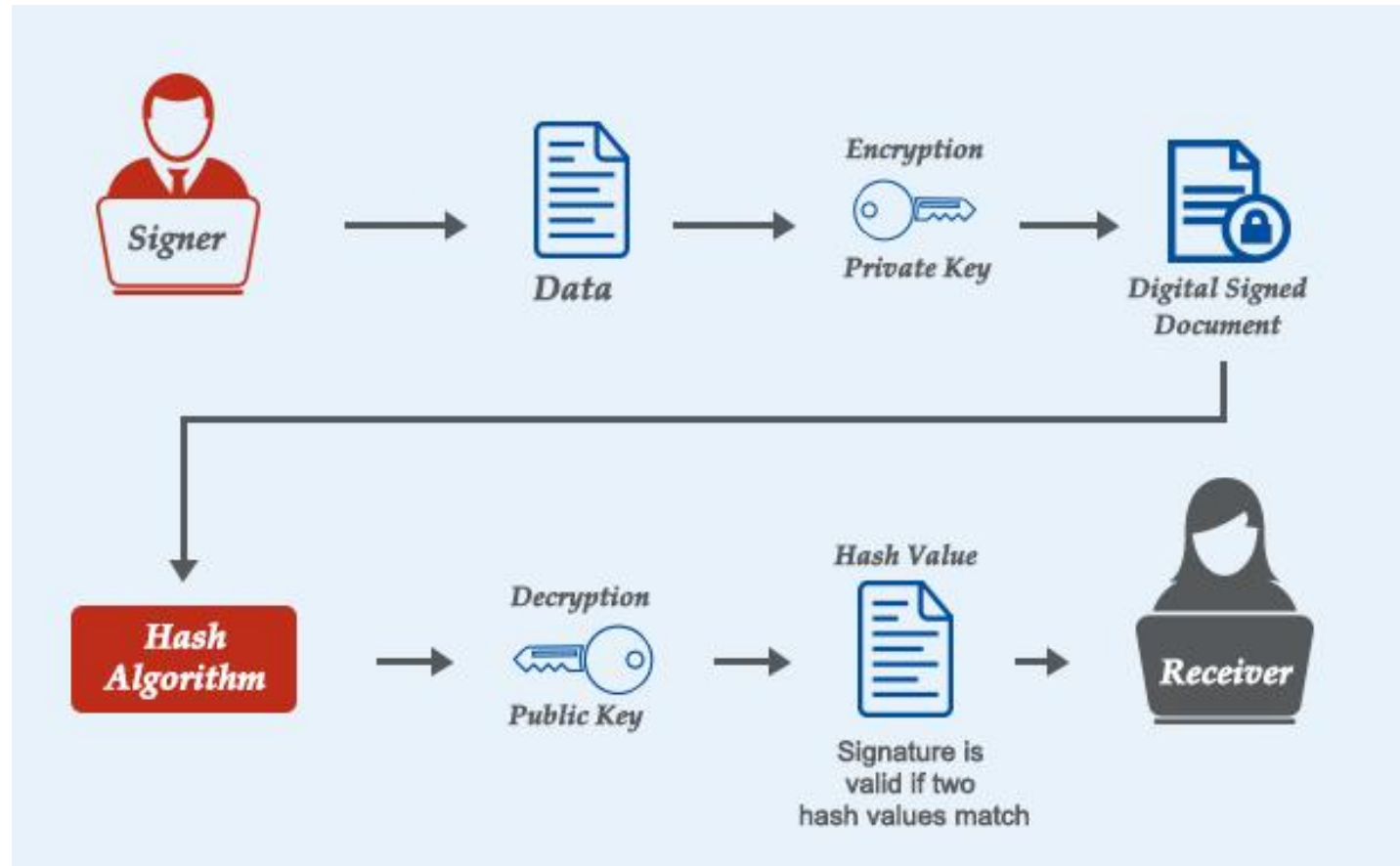
Hash Function (or Hashing)



Authentication and Digital Signature

- Authentication is a process, whereby the system gathers and builds up information about the user to assure that the user is genuine.
- used to ensure the digital message recipient of the identity of the sender and the integrity of the message
- Digital signatures ensure that the person whose signature the system is authenticating is indeed the true person.
- **Secure digital signature** system consists of two parts:
 - a method of signing a document
 - authentication that the signature was actually generated by whoever it represents.

Authentication and Digital Signature



Authentication and Digital Signature

- Authentication of users or user surrogates is usually based on checking one or more of the following user items:
 - Username (sometimes screen name).
 - Password
 - Biometrics like retinal images
 - Fingerprints
 - Physical location
 - Identity cards

Privacy

- **Privacy** is a human attribute consisting of four elements of solitude, anonymity, intimacy, and reserve.
 - They are rights everyone should have these four elements
- We put these rights into two categories.
 - Control of external influences:
 - **Solitude**: The right to be alone without disturbances
 - **Anonymity**: The right to have no public personal identity
 - **Intimacy**: The right not to be monitored
 - Control of personal information
 - **Reserve**: The right to control one's personal information including the methods of dissemination of that information.

Privacy

- **Privacy** is a human attribute consisting of four elements of solitude, anonymity, intimacy, and reserve.
 - They are rights everyone should have these four elements
- We put these rights into two categories.
 - Control of external influences:
 - **Solitude**: The right to be alone without disturbances
 - **Anonymity**: The right to have no public personal identity
 - **Intimacy**: The right not to be monitored
 - Control of personal information
 - **Reserve**: The right to control one's personal information including the methods of dissemination of that information.

Types of Privacy

- **Personal Privacy:**

- Involves the privacy of personal attributes
- Ex: US Fourth Amendment → right of the people to be secure in their persons, houses, papers, and effects, against unreasonable searches and seizures.

- **Informational Privacy**

- protection of unauthorized access to information itself, like Personal information, financial information , Medical information, and the Internet.

- **Institutional Privacy**

- Institutions data needs to be ?
- Example: Samsung's proprietary source code → ChatGPT to optimize it.

Institutional Privacy

Who is responsible?

Data Controllers?

- Executives and Senior Officials
- Privacy Officers
- IT Department



Value of Privacy

- **Facebook–Cambridge Analytica Scandal (2018)**
 - A third-party developer collected data $\approx$ 87 million Facebook users
 - Using personality quiz $\rightarrow$ no explicit consent $\rightarrow$ sold it to Cambridge Analytica
 - \$5 billion FTC fine for Facebook + massive, long-lasting reputational hit.
- **Equifax Data Breach (2017)**
 - access to the personal information of 147 million people (e.g. SSN)
 - Equifax paid a \$700 million settlement.
- **Apple's "App Tracking Transparency" (2021)**
 - prompt asking users for permission to track their data across other apps and websites
 - Give users control, help to protect their data, forcing companies to rethink tracking-dependent business models.

Value of Privacy

- three attributes of privacy: personal identity, autonomy, and social relationships
 - **Personal identity:** safeguard personal identity
 - It is valuable because it preserves personal privacy.
 - **Autonomy:** preserve individual autonomy in decision-making: Less known information → more autonomy
 - People will challenge one's autonomy depending on the quantity, quality, and value of information they have about that individual. They tend to establish relationships and associations.
 - **Social relationships:** support social relationships

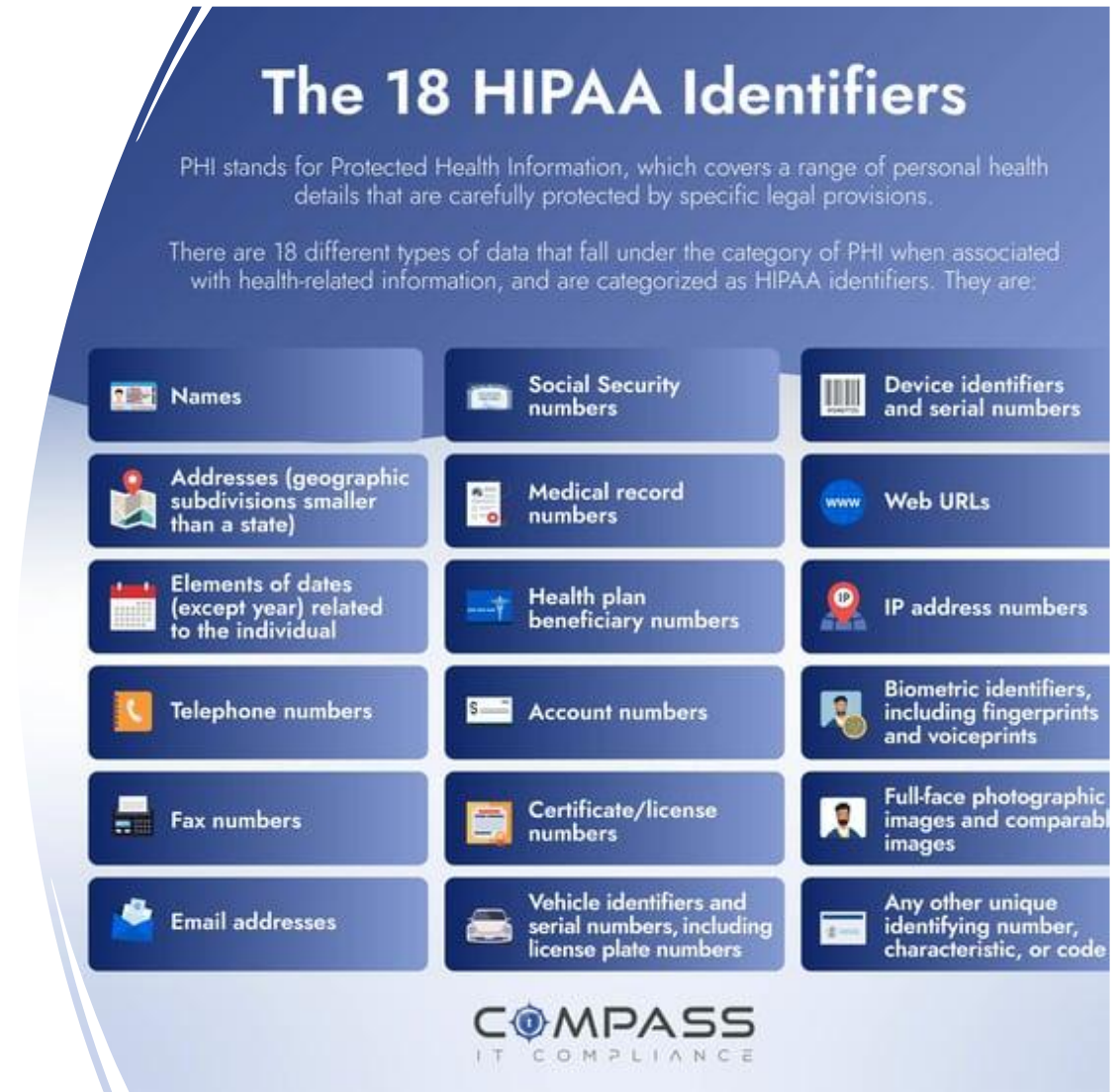
Value of Privacy

Case Study:

The 18 HIPAA Identifiers:

- Via [HIPAA Privacy Rule](#)
 - (45 CFR Parts 164: 164.514 B2)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164>



Privacy Violations and Legal Implications

- contributing **factors** or **causes** of violations.
 - Consumers **give up personal information** when register at Web, shopping malls in order to win prize.
 - **lack** the knowledge: little bit of information → big invasion of privacy
 - **Inadequate** privacy policies
 - **Failure** of institutions to **follow** their own **privacy policies** (compliance and auditing)
 - **Internet temptation** enables businesses to reach individuals in a very short time in the privacy of their homes and offices.

Privacy Violations and Legal Implications

- **Intrusion** – wrongful entry (hacking)
- **Misuse of information**
 - we involuntarily give off personal information businesses collect it
- **Interception of information**
 - eavesdropping
- **Surveillance**
- **Information matching** using unrelated databases -usually illegally

Privacy Protection and Civil Liberties

- No one agreed upon set of civil liberties
- Most accepted set of civil liberties is grouped into the following categories:
 - criminal justice that includes police powers, personal liberty, and the right to a fair trial
 - Basic freedoms of speech, assembly, association, movement, and no discrimination
 - Freedom of information
 - Communications and privacy.

Privacy Protection and Civil Liberties

- With technology, detailed information and products can very easily and cheaply be moved, merged, compared, and shared.
 - network scanning and spying software tools vs privacy
- Law enforcement agencies (like FBI) → track down criminals,
- accessing and sharing personal data by companies, associations, government agencies ***without an individual's knowledge*** is a serious threat to the security and well-being of the individual.
- There must be precautions to protect against the misuse of personal information without consent

Privacy Right Protection Guidelines/Structures

- Privacy rights fall under the following categories:
 - **Technical:** education of users and consumers to carry out self-regulation
 - Turn on cookie notices in your Web browser, and/or use cookie management software or infomediaries
 - **Contractual:** given contractual and technological protection against unauthorized reproduction or distribution
 - **Legal:** Through the enactment of laws by national legislatures and enforcement
 - Family Educational Right and Privacy Act (1974): requires schools and colleges to grant students or their parents access to student records and limits disclosure to third parties.

Code of Ethics and Code of Conduct

- SDAIA
The Implementing Regulation of the Personal Data Protection Law
- National Cybersecurity Authority (NCA)
Data Cybersecurity Control

Ethics and Privacy

- Issues involving ethics and privacy are many
 - Including morality and law
- Computer technology and cyberspace, have resulted in rapid changes in these issues and the creation of others.
- Raised more privacy questions than it has found answers to
 - Postal mail vs Email (federal offense)
 - Laws need to be in place to secure anyone of us online
 - Who should legislate them

Ethical and Legal Basis for Privacy Protection

- Security and ethical issues do not and should not **only come** into play when there is a crime committed
- These issues are also raised when individuals and companies **act** in ways that are considered harmful or have the potential of being (precaution)
- Kevin D. Mitnick, arrested by FBI for computer crimes (page 100)
 - 2000s, he became a paid security consultant, public speaker, and author
 - Tracked using his cellular phone (?)

Discussion (in Class)

- (a) Do not reveal personal information inadvertently.
- (b) Turn on cookie notices in your Web browser, and/or use cookie management software or infomediaries.
- (c) Keep a “clean” email address.
- (d) Don’t reveal personal details to strangers or just-met “friends.”
- (e) Realize you may be monitored at work. Avoid sending highly personal emails to mailing lists, and keep sensitive files on your home computer.
- (f) Beware of sites that offer some sort of reward or prize in exchange for your contact or other information.
- (g) Do not reply to spammers, for any reason.
- (h) Be conscious of Web security.
- (i) Be conscious of home computer security.
- (j) Examine privacy policies and seals.
- (k) Remember that you alone decide what information about yourself to reveal—when, why, and to whom.
- (l) Use encryption!

Discussion (in Class)

- Attempt to draft an ethical framework discussed here.
 - What should be included in it?
 - Is there a need for a legal framework also?
 - What should be in the legal framework?
 - Who should enact the laws in the framework?

Legal Framework

Privacy and Data Ethics Organization

- [General Data Protection Regulation \(GDPR\)](#) European Union Regulation
- [California Consumer Privacy Act \(CCPA\)](#)